

Engineering Document E18 — Security, Identity & Zero-Trust Architecture

Product Name: HQ

Engineering Package: Version 1.0

Purpose

This document defines the complete security architecture for HQ.

Security is not a single feature—it is a foundational capability embedded into every layer of the platform.

HQ adopts a **Zero-Trust Security Model**, meaning no user, executive, service, or integration is trusted by default.

Every action must be authenticated, authorized, validated, logged, and monitored.

Vision

HQ should be secure enough for:

- Startups
- SMBs
- Government organizations
- Financial institutions
- Healthcare providers
- Enterprise customers

Security should scale with the platform.

Core Security Principles

HQ follows these principles:

- Never Trust
 - Always Verify
 - Least Privilege
 - Defense in Depth
 - Secure by Default
 - Privacy by Design
 - Continuous Monitoring
 - Complete Auditability
-

Zero Trust Model

User / AI Executive / API / Integration

↓

Identity Verification

↓

Authentication

↓

Policy Evaluation

↓

Authorization

↓

Security Validation

↓

Execute Action

↓

Audit Logging

↓

Continuous Monitoring

No request bypasses this pipeline.

Identity Architecture

Every identity within HQ is unique.

Supported identities:

- Human Users
- Organizations
- AI Executives
- APIs
- Background Workers
- External Integrations
- System Services

Every identity receives a unique ID.

Authentication

Primary authentication:

- Firebase Authentication

Supported methods:

- Google
- Email & Password

Future support:

- Microsoft
- GitHub
- Apple
- Magic Link
- Enterprise SSO
- SAML
- OAuth2

Multi-Factor Authentication

Supported methods:

- Authenticator App
- Passkeys
- Security Keys
- Email Verification

MFA policies are configurable per organization.

Authorization

Authorization uses three layers.

Layer 1

Role-Based Access Control (RBAC)

Roles:

- Owner
 - Admin
 - Manager
 - Member
 - Viewer
-

Layer 2

Entitlement Engine

Controls feature access.

Examples:

- AI Generation
- Billing
- Analytics
- Executive Access
- API Access

Layer 3

Policy Engine

Evaluates:

- Organization policies
- Security rules
- Compliance requirements
- Mission restrictions

Final authorization occurs here.

Policy Engine

Every sensitive action is evaluated.

Example:

Action Requested

↓

Authentication

↓

Role Check

↓

Entitlement Check

↓

Policy Evaluation

↓

Risk Assessment

↓

Decision

Possible outcomes:

- Allow
- Deny
- Require Approval
- Require MFA
- Escalate

Executive Security

Every AI Executive receives:

- Unique Identity
- Limited Permissions
- Tool Restrictions
- Memory Restrictions
- Organization Isolation

Executives never inherit unrestricted permissions.

Tool Permissions

Each tool defines:

- Allowed Executives
- Allowed Organizations
- Usage Limits
- Security Requirements

Executives cannot access unauthorized tools.

Organization Isolation

Organizations are isolated.

Isolation includes:

- Database Records
- Storage
- Memory
- Missions
- Analytics
- Billing
- Audit Logs

Cross-organization access is impossible unless explicitly supported in future enterprise collaboration features.

API Security

Every request includes:

- Authentication
- Authorization
- Request ID
- Validation
- Rate Limiting

Invalid requests are rejected immediately.

Rate Limiting

Limits apply to:

- Login
- AI Requests

- Uploads
- API Calls
- Search
- Billing Operations

Organizations receive configurable limits.

Encryption

Data In Transit:

- TLS

Data At Rest:

- Database Encryption
- Storage Encryption

Sensitive Fields:

- Application-Level Encryption

Secrets:

- Google Secret Manager
-

Secure Session Management

Sessions include:

- Expiration
- Device Tracking
- Refresh Tokens
- Revocation
- Forced Logout

Users can terminate active sessions.

Audit Logging

Every critical action is recorded.

Examples:

- Login
- Logout
- Executive Decisions
- Billing Changes
- Permission Updates
- Policy Violations
- Mission Approvals

Audit records are immutable.

Threat Detection

Monitor:

- Suspicious Login Attempts
- Credential Abuse
- Excessive AI Usage
- Unauthorized API Calls
- Token Abuse
- Policy Violations

Security alerts are generated automatically.

AI Security

Protect against:

- Prompt Injection
- Data Leakage

- Unauthorized Context Access
- Unsafe Tool Invocation
- Cross-Organization Information Exposure

The Prompt Engine validates all context before execution.

Human Approval Gates

Certain actions require explicit approval.

Examples:

- Subscription Changes
- Organization Deletion
- Executive Policy Changes
- Sensitive File Deletion
- Public Publishing

No automated bypass is permitted.

Compliance Readiness

Architecture supports:

- GDPR
- SOC 2
- ISO 27001
- HIPAA (future)
- Enterprise Security Policies

Compliance is considered during system design.

Security Monitoring

Track:

- Failed Logins
- MFA Usage
- API Abuse
- Permission Violations
- Security Alerts
- Executive Policy Violations

Real-time dashboards support security operations.

Incident Response

Security incident lifecycle:

Detection



Classification



Containment



Investigation



Recovery



Post-Incident Review

Lessons learned feed back into the security program.

Secure Development

Engineering requirements:

- Code Reviews
- Dependency Scanning
- Secret Scanning
- Static Analysis
- Automated Security Tests

Security is integrated into CI/CD.

Future Enhancements

Supports:

- Adaptive Authentication
 - Behavioral Biometrics
 - AI-Assisted Threat Detection
 - Hardware Security Keys
 - Enterprise Identity Federation
 - Fine-Grained Attribute-Based Access Control (ABAC)
-

Success Criteria

The Security, Identity & Zero-Trust Architecture succeeds when:

- Every request is authenticated and authorized.
 - Organizations remain completely isolated.
 - Executives operate with least privilege.
 - Sensitive actions are fully auditable.
 - Security policies are enforced consistently across all services.
 - The platform is prepared for enterprise security requirements.
-

Conclusion

The HQ Security, Identity & Zero-Trust Architecture establishes a comprehensive security framework that protects every layer of the platform.

By combining strong identity management, layered authorization, a centralized Policy Engine, Zero-Trust principles, immutable audit logging, AI-specific safeguards, and continuous monitoring, HQ becomes a secure foundation for autonomous AI executives, enterprise collaboration, and long-term organizational trust.